

Threat Intelligence Report: Analisi Traffico di Rete e Rilevamento IOC

Autore: Francesco Sardi

Data: 06/02/2026

Oggetto: Analisi di attività di ricognizione attiva e identificazione asset vulnerabile (*Metasploitable*)

Executive Summary

Il presente documento riporta l'analisi tecnica di un file di log di rete acquisito tramite Wireshark. L'indagine si concentra su attività di rete anomale rilevate tra due host interni. L'obiettivo primario è l'identificazione di Indicatori di Compromissione (*IOC*), la ricostruzione della catena di attacco e la definizione di contromisure.

L'analisi ha evidenziato una fase di **Ricognizione Attiva** (*Scanning*) condotta da un host interno verso un target vulnerabile. È stato identificato l'uso di strumenti automatizzati per l'enumerazione dei servizi, rivelando una configurazione di sistema critica attribuibile a un ambiente *Metasploitable*. Il report include raccomandazioni per il contenimento immediato e la mitigazione a lungo termine.

Overview:

- Identificazione e correlazione degli IOC (*IP, Porte, Pattern di traffico*).
- Ricostruzione della metodologia di attacco.
- Definizione del piano di rimediazione.

Campaign Delivery

Analisi preliminare

Dall'analisi preliminare dei pacchetti, sono stati isolati due host appartenenti alla stessa sottorete locale, indicando una potenziale minaccia interna o un *movimento laterale* da una macchina già compromessa.

- **IP Attaccante):** 192.168.200.100
- **Target (Vittima):** 192.168.200.150

Analisi dei Pattern di Traffico (Wireshark)

L'analisi temporale dei pacchetti mostra un volume elevato di richieste di connessione generate dall'Attaccante verso il Target su un ampio campo di porte di destinazione.

Comportamento su Porte Chiuse: Si osservano tentativi di connessione sequenziali verso porte non standard.

- **Pattern:** SYN → RST, ACK
- **Interpretazione:** L'attaccante invia un pacchetto di sincronizzazione. Il target risponde con un *Reset* (RST), indicando che la porta è chiusa. Questo comportamento è tipico di uno scan massivo.

21	36	774885698	192.168.200.100	192.168.200.150	TCP	60	443	→	33878	[RST, ACK] Seq=1 Ack=1 Win=0 Len=0
22	36	774885737	192.168.200.100	192.168.200.150	TCP	60	354	→	58636	[RST, ACK] Seq=1 Ack=1 Win=0 Len=0
23	36	774885776	192.168.200.100	192.168.200.150	TCP	60	135	→	52358	[RST, ACK] Seq=1 Ack=1 Win=0 Len=0
24	36	774790464	192.168.200.100	192.168.200.150	TCP	66	41304	→	23	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
25	36	774711072	192.168.200.100	192.168.200.150	TCP	66	56120	→	111	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
26	36	775111104	192.168.200.100	192.168.200.150	TCP	60	303	→	40138	[RST, ACK] Seq=1 Ack=1 Win=0 Len=0
27	36	775141273	192.168.200.100	192.168.200.150	TCP	74	21	→	41182	[SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535438 WS=64
28	36	775174048	192.168.200.100	192.168.200.150	TCP	66	41182	→	21	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
29	36	775376080	192.168.200.100	192.168.200.150	TCP	74	59174	→	113	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
30	36	775396064	192.168.200.100	192.168.200.150	TCP	74	55656	→	22	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
31	36	775524204	192.168.200.100	192.168.200.150	TCP	74	53062	→	80	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535439 TSecr=0 WS=128
32	36	775580800	192.168.200.100	192.168.200.150	TCP	60	113	→	59174	[RST, ACK] Seq=1 Ack=1 Win=0 Len=0
33	36	775619454	192.168.200.100	192.168.200.150	TCP	66	41304	→	23	[RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
34	36	775652497	192.168.200.100	192.168.200.150	TCP	66	56120	→	111	[RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466

Comportamento su Porte Aperte: L'analisi delle righe 65-86 evidenzia un pattern distinto che conferma l'avvenuta enumerazione dei servizi attivi.

65	36	776914772	192.168.200.100	192.168.200.150	TCP	66	33042	→	445	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
66	36	776941020	192.168.200.100	192.168.200.150	TCP	66	40990	→	139	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
67	36	776962320	192.168.200.100	192.168.200.150	TCP	66	60632	→	25	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
68	36	776983078	192.168.200.100	192.168.200.150	TCP	66	37282	→	63	[ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466

- **Riga 45:** [SYN] - Richiesta di connessione in ingresso.
- **Riga 57:** [SYN, ACK] - Il target accetta la connessione.
- **Riga 65:** [ACK] - Handshake completato (Connessione stabilita).
- **Riga 86:** [RST] o [FIN] - Chiusura immediata della connessione.

tcp.stream eq 15						
No.	Time	Source	Destination	Protocol	Length	Info
45	36.776385604	192.168.200.100	192.168.200.150	TCP	74	33042 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535440 TSecr=0 WS=128
57	36.776904828	192.168.200.100	192.168.200.150	TCP	74	445 → 33042 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535440 WS=64
65	36.776914772	192.168.200.100	192.168.200.150	TCP	66	33042 → 445 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
86	36.777093298	192.168.200.100	192.168.200.150	TCP	66	33042 → 445 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535441 TSecr=4294952466

La connessione seguita da una disconnessione immediata senza scambio di dati è la principale caratteristica di un **TCP Connect Scan** (*nmap -sT*). L'attaccante è interessato solo a verificare lo stato della porta (*Open/Closed*) e non a interagire con il servizio in questa fase.

Risultati della Ricognizione

Lo scan ha esposto una superficie di attacco estremamente ampia. Sull'host vittima (192.168.200.150) sono stati rilevati i seguenti servizi aperti:

Porta	Servizio
21	FTP
23	Telnet
25	SMTP
53	DNS
80	HTTP
111	//
139	Netbios
445	//
512	//
513	//
514	//

La presenza simultanea di servizi vecchi vulnerabili e porte standard aperte conferma con alta probabilità che la macchina target è una **Metasploitable** intenzionalmente vulnerabile per scopi didattici o di test.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	192.168.200.150	192.168.200.255	BROWSER	286	Host Announcement METASPLOITABLE, Workstation, Server, Print Queue Server, Xenix Server, NT Workstation, NT Server, Potential Browser

Ipotesi sui Vettori di Attacco

Basandosi su ciò che si è trovato l'attaccante ha completato la fase di Reconnaissance e si sta muovendo verso la fase di sfruttamento delle vulnerabilità trovate.

1. **Metodologia:** Scansione attiva tramite **Nmap** (*Port Scanning*).
2. **Vettori Potenziali Successivi:**
 - **Brute Force / Dictionary Attack:** Vista la presenza delle porte 21 (*FTP*) e 23 (*Telnet*), è altamente probabile un tentativo di indovinare le credenziali.
 - **Exploitation di Vulnerabilità Note:** Servizi come SMB (*445*) sono vettori comuni per l'esecuzione di codice remoto.
 - **Backdoor:** Sfruttamento della backdoor per ottenere una root shell immediata.

Piano di Rimediazione e Mitigazione

Azioni di Contenimento Immediato (Breve Termine)

1. **Network Isolation:** Isolare logica o fisica dell'host vittima *192.168.200.150* dalla rete di produzione per prevenire movimenti laterali.
2. **Firewall Blocking:** Implementare una regola di blocco sul firewall per tutto il traffico proveniente dall'IP Attaccante *192.168.200.100*.

Azioni di Prevenzione (Lungo Termine)

1. **Riduzione della Superficie d'Attacco:**
 - Disabilitare immediatamente i servizi vecchi non criptati (*Telnet, FTP*).
 - Mantenere aperte solo le porte strettamente necessarie al business (*es. solo 80/443 per un web server*).
2. **Crittografia:** Migrazione obbligatoria verso protocolli sicuri (*SSH al posto di Telnet, SFTP al posto di FTP, HTTPS al posto di HTTP*).
3. **Segmentazione di Rete:** Implementazione di VLAN per segregare gli ambienti di test.
4. **Vulnerability Management:** Istituire una policy di scansione periodica e patch management automatico.